

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Two Zero-day Supply Chain Attacks Found in the Python Package Index

Date of Publication

December 22, 2022

Admiralty Code

A1

TA Number

TA2022311

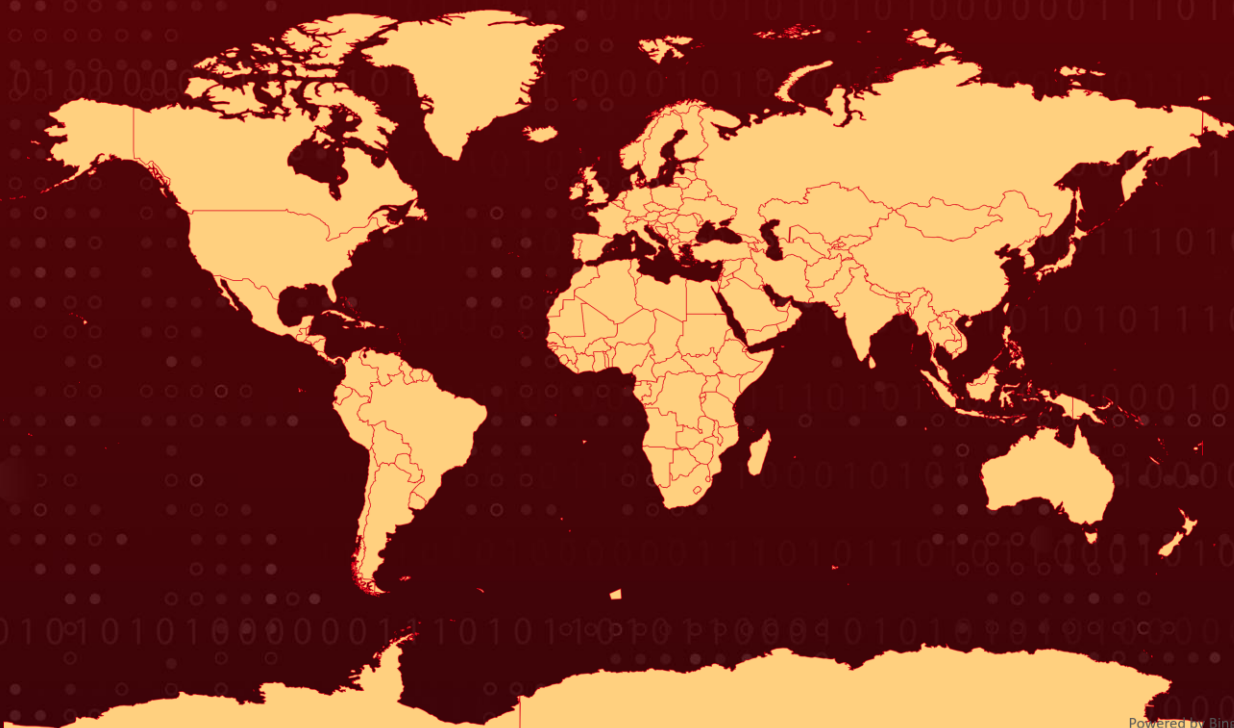
Summary

First appeared: December 6, 2022

Attack Region: Worldwide

Attack: Malware execution causes systems and exposes users to vulnerabilities.

Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

A zero-day supply chain attack called "**aioconsole**" was discovered on December 9, 2022 in a Python package published on the Python Package Index (PyPI) on December 6, 2022. All three versions of the package were published on the same day and contain malicious code that writes a binary file called "test.exe" and executes it as part of the installation process.

#2

Several vendors have flagged the binary file as malicious according to a VirusTotal entry. This attack is similar to another zero-day PyPI attack called "shaderz" and does not include a clear description of its project or source page. It is important to be cautious when installing Python packages from unknown sources as they may contain malware.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0002</u> Execution	<u>TA0002</u> Execution	<u>TA0008</u> Lateral Movement
<u>TA0005</u> Defense Evasion	<u>TA0004</u> Privilege Escalation	<u>TA0007</u> Discovery	<u>TA0003</u> Persistence
<u>TA0010</u> Exfiltration	<u>T1204</u> User Execution	<u>T1204.002</u> Malicious File	<u>T1574</u> Hijack Execution Flow
<u>T1574.005</u> Executable Installer File Permissions Weakness	<u>T1059</u> Command and Scripting Interpreter	<u>T1059.006</u> Python	<u>T1547</u> Boot or Logon Autostart Execution
<u>T1546</u> Event Triggered Execution	<u>T1546.016</u> Installer Packages	<u>T1083</u> File and Directory Discovery	<u>T1546</u> Malware
<u>T1105</u> Ingress Tool Transfer	<u>T1587</u> Develop Capabilities	<u>T1588</u> Obtain Capabilities	

Indicator of Compromise (IOCs)

TYPE	VALUE
SHA256	52e6efbbfb1fdeb976e2464c542bc17747d213d67f28dff4d7df0879df23f d7e 8124cec491e0249bc4a9f3f9d3755201b0e8c28068ce8c4b528217dbb94 afd13 Fd9f944fafb58faf783fdf4f8638d281a429b84cdb119756e6d7d92b31a07 9de 33df1d9c50a9bd9d3e71dc61c0a7f41f7ca51612e9c3babcea927adde169 e62d d1f0583169acde756793d7d5d69afbb72331c931a88749eab14f28ecda3 ef5ce
IPV4	104[.]20[.]67[.]143 104[.]20[.]68[.]143 172[.]67[.]34[.]170 185[.]106[.]92[.]188

TYPE	VALUE
URLs	cdn[.]discordapp[.]com/attachments/1045000289708687390/1045159487079723058/stub[.]exe cdn[.]discordapp[.]com/attachments/1045000289708687390/1045158219024171169/main[.]exe

References

<https://www.fortinet.com/blog/threat-research/new-supply-chain-attack-uses-python-package-index-aioconsole>

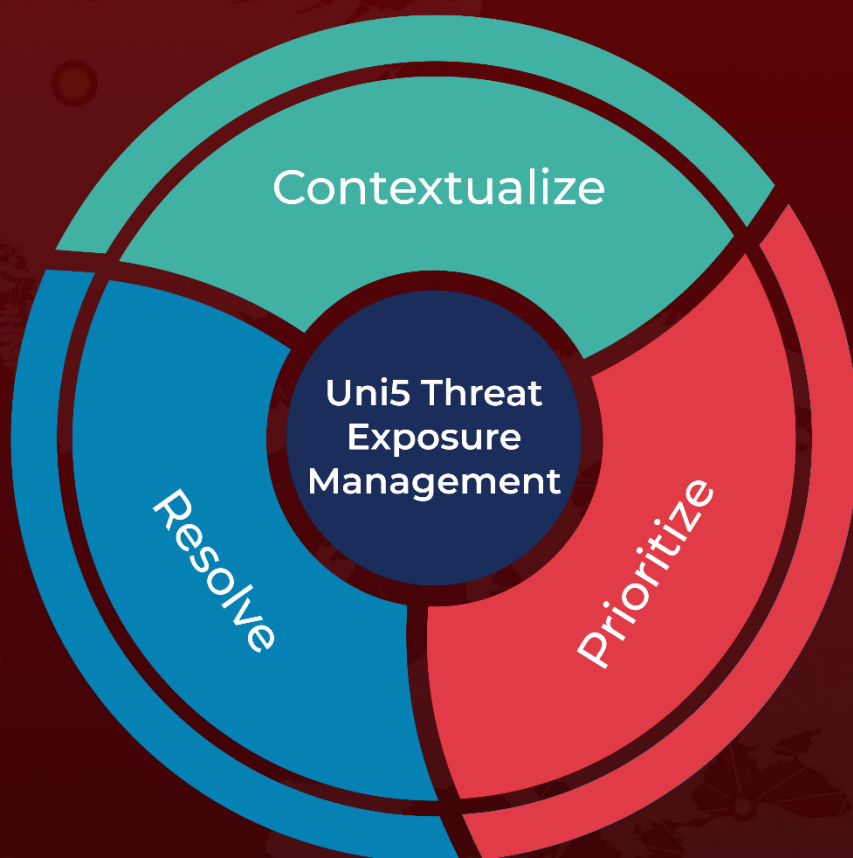
https://www.fortinet.com/blog/threat-research/supply-chain-attack-new-malicious-python-package-shaderz?utm_source=blog&utm_medium=blog&utm_campaign=supply-chain-attack-new-malicious-python-package-shaderz

https://www.fortinet.com/blog/threat-research/supply-chain-attack-via-new-malicious-python-package-shaderz-part-2?utm_source=blog&utm_medium=blog&utm_campaign=partII

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 22, 2022 • 6:30 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com